

22_EXPLOITATION_VM_RUNBOOK_REX

Exploitation VM, runbook et REX incidents - Daylight / Cyber Trust

Objectif

Ce livrable rend concrete la partie exploitation portee par Mahamadou : etat des VM, procedure de redemarrage du lab, controles avant demonstration, conduite incident et retour d'experience. Il transforme les playbooks en actions verifiables.

Fichiers associes :

Fichier	Usage
`config/lab/daylight_vm_inventory.csv`	Inventaire des VM/conteneurs, IP, services et responsable.
`config/lab/daylight_lab_runbook.csv`	Etapes de relance du lab avec commandes et preuves attendues.
`config/lab/daylight_rex_scenarios.csv`	Scenarios REX pre-remplis pour incidents de demo.
`tools/preflight_demo.ps1`	Controle non destructif avant enregistrement.

1. Inventaire lab

L'inventaire complet est dans config/lab/daylight_vm_inventory.csv.

Nom	Type	IP	Role	Responsable
`wazuh-manager`	Docker / VM	`10.10.50.10` ou `localhost`	SIEM, indexer, dashboard	Youssef
`serveur-01`	Conteneur Ubuntu	`10.10.20.20` ou reseau Docker	SSH, rsyslog, auth.log	Mahamadou
`poste-01`	Poste Windows	DHCP ou IP fixe	Agent endpoint, SCA, USB	Youssef
`pfsense-fw-01`	VM pfSense	`10.10.10.1` a `10.10.50.1`	Firewall, segmentation, syslog	Yvan + Mahamadou
`daylight-app-01`	VM/conteneur optionnel	`10.10.30.20`	Application metier simulee	Kilyan + Youssef
`admin-01`	Poste admin	`10.10.40.21`	Acces pfSense/Wazuh	Mahamadou

2. Runbook de redemarrage rapide

Objectif : remettre le lab en etat en moins de 15 minutes avant la video.

Ordre	Action	Commande / ecran	Preuve attendue
1	Lancer Docker Desktop	Application Windows	Docker daemon repond.
2	Preflight initial	`powershell -File .\tools\preflight_demo.ps1 -WriteReport`	Rapport avec outils locaux OK.
3	Lancer Wazuh	Depuis la racine technique du lab ; si elle contient `package.json`, utiliser `npm run lab:start`	Dashboard accessible.
4	Demarrer `serveur-01`	`docker start serveur-01`	Conteneur running.
5	Verifier SSH/rsyslog	`docker exec serveur-01 service ssh status`	SSH actif.
6	Generer logs demo	`python .\tools\generate_demo_logs.py`	5 fichiers `.log`.
7	Dry-run syslog	`python .\tools\send_demo_logs_to_syslog.py --dry-run`	16 evenements affiches.
8	Relancer annexe captures	`python .\tools\build_capture_annex.py`	`16_ANNEXE_CAPTURES_WAZUH.md` a jour.
9	Preflight final	`powershell -File .\tools\preflight_demo.ps1 -WriteReport`	Seuls captures/video restent en warning si lab non filme.

3. Commandes d'exploitation utiles

Docker

Lister les conteneurs :

```

'''
docker ps -a
'''

```

Demarrer le serveur simule :

```

'''
docker start serveur-01
'''

```

Voir les logs du serveur :

```

'''
docker logs serveur-01 --tail 50
'''

```

Entrer dans le conteneur :

```

'''
docker exec -it serveur-01 bash
'''

```

Wazuh

Verifier l'accès dashboard :

```

'''
Invoke-WebRequest -UseBasicParsing https://localhost
'''

```

Rejouer les logs demo vers le collecteur local :

```

'''
python .\tools\send_demo_logs_to_syslog.py --host 127.0.0.1 --port 514 --protocol udp
'''

```

pfSense

Captures prioritaires :

```

'''
Firewall > Rules > USERS
Status > System Logs > Settings
Status > System Logs > Firewall
'''

```

4. Procedure incident concrete

Incident A - Brute force SSH 5712

Etape	Action
Detection	Alerte Wazuh `5712` ou recherche SSH.
Verification	Source IP, utilisateur vise, nombre d'echecs, succes eventuel apres echecs.
Confinement	Bloquer l'IP source si attaque confirmee ; verifier le compte.
Eradication	Changer mot de passe si compromis ; verifier clefs SSH.

Retablisement	Confirmer retour a un volume normal.
REX	Cause, delai detection, delai qualification, action preventive.

Incident B - Acces dossier patient 100120

Etape	Action
---	---
Detection	Alerte `100120` ou log `patient_record_access risk=high`.
Verification	Utilisateur, role, centre, patient_id, horaire, justification metier.
Confinement	Suspendre la session ou le compte si l'accès est non legitime.
Escalade	Referent Daylight + DPO si suspicion confirmee.
Retablisement	Valider droits applicatifs et traces.
REX	Mesure corrective : controle d'accès, formation, alerte seuil.

Incident C - Mouvement inter-VLAN 110020

Etape	Action
---	---
Detection	pfSense bloque USERS vers MGMT/SERVERS, alerte Wazuh `110020`.
Verification	IP source, poste, destination, port, repetition.
Confinement	Garder blocage pfSense ; isoler le poste si comportement anormal.
Investigation	Verifier malware, processus, utilisateur connecte.
Retablisement	Nettoyer ou reinstaller poste, confirmer absence de nouvelles tentatives.
REX	Durcissement endpoint, controle egress, sensibilisation.

5. Fiche REX prete a remplir

Champ	Exemple
---	---
ID incident	`INC-DAYLIGHT-2026-001`
Date/heure detection	`2026-06-23 09:24`
Source	Wazuh / pfSense / application
Regle	`100120`
Severite	Critique
Systeme touche	`daylight-app-01`
Impact potentiel	Donnees patients / RGPD
Cause racine	Droits applicatifs trop larges ou compte compromis
Action immediate	Suspension session, verification utilisateur
Action corrective	Revue RBAC applicative
Action preventive	Alerte seuil + revue mensuelle acces sensibles
Responsable suivi	Mahamadou + Kilyan
Statut	Ouvert / En cours / Clos

6. Ce que Mahamadou peut montrer a l'oral

> Mon role est de rendre le demontreurs exploitable : je sais relancer les VM et conteneurs, verifier les services, rejouer les logs, appliquer les playbooks et produire un REX apres incident. Cela evite d'avoir seulement des alertes ; on montre aussi comment le SOC fonctionne au quotidien.

7. Captures a produire

Capture	Ecran
---	---
`CAP-25_preflight-demo-ok.png`	Rapport preflight apres relance.
`CAP-26_docker-conteneurs-lab.png`	`docker ps -a` avec Wazuh/serveur si disponibles.
`CAP-27_rejeu-logs-dry-run.png`	`send_demo_logs_to_syslog.py --dry-run`.
`CAP-28_rex-incident-rempli.png`	Exemple de REX incident `100120` ou `110020`.

8. Plan B si Docker/Wazuh est eteint

Si Docker ou Wazuh ne démarre pas pendant la soutenance :

1. Montrer preflight-demo-report.txt.
2. Expliquer que Docker daemon est le prerequisite.
3. Montrer Demo_Logs/ et le dry-run syslog.
4. Montrer les playbooks et la fiche REX.
5. Ne pas prétendre que les captures Wazuh sont présentes si elles ne le sont pas.

Phrase propre :

> Le lab dépend de Docker/Wazuh. Quand le service est éteint, le preflight le signale et nous utilisons les logs, runbooks et playbooks pour démontrer la reproductibilité sans inventer de preuves.